Messagerie souveraine de l'administration

Présentation du projet

Sprint technique pré-hackathon 2026 (Hackathon 226) · Challenge du MTDPCE, Direction générale de la transformation digitale · Ouagadougou, novembre 2026

> Ce document présente notre réponse au challenge « La messagerie souveraine de l'administration ». Nous proposons une messagerie instantanée destinée aux agents publics, chiffrée de bout en bout, installée sur l'infrastructure de l'État et réservée aux agents préalablement enrôlés. Elle repose sur le protocole Matrix et sur des logiciels open source éprouvés : Synapse pour le serveur, Element pour l'application des agents et Keycloak pour la gestion des identités. Une console d'administration, seule brique développée par l'équipe, permet de retirer un agent de la messagerie en un clic. L'ensemble s'installe par une seule commande et ne dépend d'aucun service extérieur.

1. Contexte et objectifs

Les agents publics échangent chaque jour des informations de service, parfois sensibles, sur des messageries grand public. Les serveurs de ces applications, leurs règles d'utilisation et les données qu'elles collectent échappent entièrement à l'État.

Le challenge demande une messagerie instantanée pour l'administration (messages, groupes, fichiers), hébergeable sur l'infrastructure de l'État et offrant un niveau de sécurité élevé. Il impose un socle obligatoire :

- un chiffrement de bout en bout des messages et des fichiers, fondé sur un protocole éprouvé, sans aucune cryptographie développée par l'équipe ;
- un hébergement souverain, installable en une seule commande et sans service tiers ;
- une identité vérifiée : seuls des agents enrôlés entrent, avec un second facteur d'authentification et une gestion des rôles ;
- une révocation immédiate : un agent révoqué perd l'accès sur tous ses appareils ;
- une minimisation des métadonnées, avec une description honnête de ce que le serveur voit malgré tout ;
- une note de sécurité décrivant les menaces, les protections et les limites.

Notre objectif est de couvrir entièrement ce socle, de façon vérifiable devant le jury, puis d'y ajouter des fonctions réellement utiles à l'administration burkinabè.

2. Principes de conception

Le chiffrement se fait chez l'agent. Les messages et les fichiers sont chiffrés sur le téléphone ou l'ordinateur de l'agent avant d'être envoyés, et déchiffrés uniquement sur les appareils

des destinataires. Le serveur ne reçoit et ne stocke que du contenu illisible ; les clés privées ne quittent jamais les appareils.

L'État héberge tout. L'ensemble de la plateforme tourne sur un serveur maîtrisé par l'administration. Aucun service extérieur n'est sollicité, ni pour les notifications, ni pour la vérification des clés, ni pour des statistiques d'usage.

On n'entre que si l'on a été enrôlé. Il n'existe pas d'inscription libre. Chaque agent est créé par un administrateur, avec son ministère, sa fonction et son rôle, et se connecte avec un mot de passe et un code à usage unique.

L'administration garde la main. Un départ ou la perte d'un téléphone se traite en un clic : l'agent perd l'accès sur tous ses appareils, quitte tous ses groupes et ne peut plus lire les nouveaux messages. Chaque révocation est tracée.

Réutiliser plutôt que réinventer. Notre niveau d'engagement open source est « Étendre et adapter » : nous partons de logiciels éprouvés et nous concentrons notre travail sur ce qui manque pour l'administration. La cryptographie n'est jamais modifiée ; elle est fournie par les bibliothèques officielles de Matrix.

3. Choix technologiques

3.1 Le protocole de chiffrement

Le challenge autorise quatre protocoles : Signal, Matrix, MLS et XMPP avec OMEMO. Nous les avons comparés sur les besoins d'une administration et sur ce qui est réalisable dans le délai du sprint.

Critère	Signal	Matrix	MLS	XMPP
Auto-hébergement sans service tiers	Difficile	Oui	Serveur à construire	Oui
Serveur et clients disponibles	Surtout mobile	Oui (web, mobile)	Non	Inégal selon les clients
Connexion unique (SSO) et API d'administration	Non	Oui	Non	Partiel
Fédération entre serveurs	Non	Oui	Non	Oui
Discrétion des métadonnées	Très bonne	Moyenne	Dépend du serveur	Moyenne
Réalisable en sept jours	Risqué	Oui	Non	Oui

Nous retenons **Matrix.** C'est le seul protocole qui offre à la fois un serveur auto-hébergeable, une application complète, la délégation de la connexion à un annuaire et une API pour désactiver les comptes, c'est-à-dire exactement ce dont l'enrôlement et la révocation ont besoin. Il permet aussi, à terme, de relier entre eux les serveurs de plusieurs ministères. Son

point faible est connu : le serveur voit davantage de métadonnées qu'avec Signal. Nous le documentons et le réduisons (voir la section 6).

3.2 Les composants

Synapse (serveur Matrix, AGPL-3.0). C'est l'implémentation de référence et la plus complète : connexion par un annuaire externe, API d'administration, politiques de conservation des messages. Il stocke et relaie le contenu chiffré sans pouvoir le lire. Les serveurs plus légers (Dendrite, Conduit) ont été écartés, car moins outillés pour l'administration.

Element (application des agents, AGPL-3.0), avec **vodozemac** (Apache-2.0). Element offre une ergonomie proche des messageries grand public et peut être traduit. Le chiffrement y est assuré par vodozemac, l'implémentation officielle d'Olm et Megolm, écrite en Rust et auditée de manière indépendante. Écrire notre propre application aurait été trop long et source d'erreurs de sécurité.

Keycloak (gestion des identités, Apache-2.0). C'est un standard dans les administrations. Il gère le protocole OpenID Connect, le second facteur par code à usage unique (TOTP), les groupes, les attributs ministère et fonction, et sa configuration peut être importée au démarrage. Les comptes internes de Synapse ont été écartés, car ils n'offrent ni second facteur ni gestion fine des rôles.

Console d'administration (développée par l'équipe, en Python avec FastAPI). C'est la seule brique que nous écrivons. Elle permet d'enrôler un agent et de le révoquer en agissant en une seule opération sur Keycloak et sur Synapse, puis vérifie que la révocation est effective et l'inscrit dans un journal d'audit. Son code est court, testé et explicable ligne par ligne.

oauth2-proxy (MIT). Il protège l'accès à la console : seule une personne connectée via Keycloak, avec second facteur, et membre du groupe des administrateurs peut y accéder, sans que nous ayons à écrire de code d'authentification.

Caddy (Apache-2.0). C'est le point d'entrée unique de la plateforme. Il gère automatiquement les certificats HTTPS et bloque l'accès public à l'API d'administration de Synapse. Nginx a été écarté, car plus verbeux et sans gestion intégrée des certificats.

PostgreSQL (licence PostgreSQL). Il héberge les bases de Synapse et de Keycloak. C'est la base recommandée par Synapse en production ; SQLite est réservé aux essais.

Docker Compose (Apache-2.0). Toute la plateforme est décrite dans des fichiers versionnés et se lance par la commande `docker compose up -d`, de manière identique sur n'importe quel serveur de l'État.

4. Architecture globale

La plateforme se compose de deux parties reliées par un point d'entrée commun. La **partie messagerie** regroupe tout ce que l'agent utilise pour échanger ; la **partie identité** regroupe tout ce qui décide qui peut entrer et permet de retirer un accès.

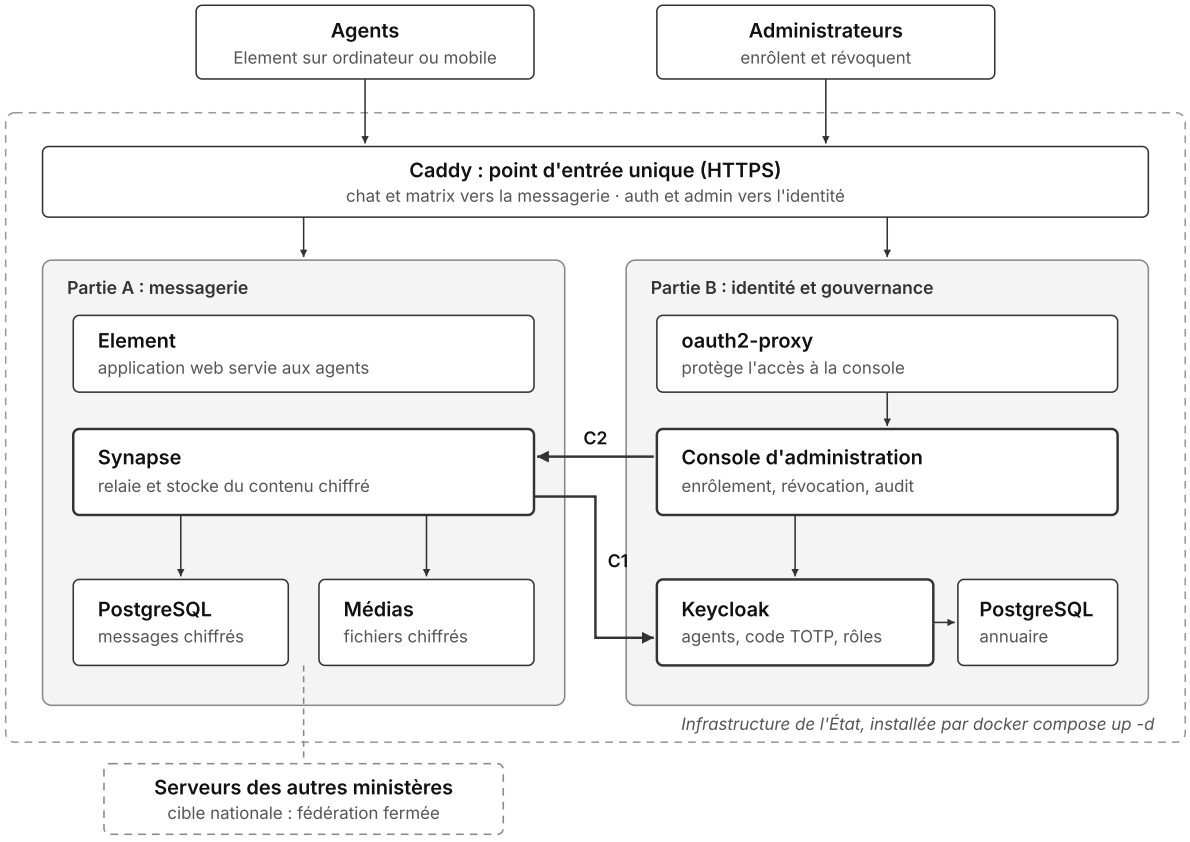


Figure 1. Architecture globale. C1 : Synapse confie la connexion des agents à Keycloak. C2 : la console désactive les comptes dans Synapse, par le réseau interne.

Le point d'entrée. Tout le trafic arrive par Caddy, qui oriente chaque adresse vers le bon service : `chat` et `matrix` vers la partie messagerie, `auth` et `admin` vers la partie identité. Les autres services n'exposent aucun port vers l'extérieur.

La partie messagerie comprend Element, servi aux agents, et Synapse, qui relaie les messages. La base de données et le stockage des fichiers ne contiennent que du contenu chiffré.

La partie identité comprend Keycloak, qui connaît les agents et vérifie leur second facteur, et la console d'administration, protégée par oauth2-proxy.

Deux points de contact seulement relient les deux parties. Par le premier (C1), Synapse délègue la connexion des agents à Keycloak et n'accepte que les membres du groupe « agents ». Par le second (C2), la console désactive les comptes dans Synapse, uniquement par le réseau interne. Cette séparation permet de développer et de tester chaque partie indépendamment, puis de les assembler sans difficulté.

À l'échelle nationale, chaque ministère pourrait disposer de son propre serveur, ces serveurs n'étant reliés qu'entre eux par une liste blanche. Une panne locale ne bloquerait pas les autres, et chaque serveur ne verrait que les métadonnées de son ministère. Le prototype, lui, repose sur un seul serveur.

5. Fonctionnement

5.1 Enrôlement et connexion d'un agent

1. L'administrateur crée l'agent : identifiant, nom, ministère, fonction et groupe « agents ».
2. À sa première connexion, l'agent choisit son mot de passe et configure son code à usage unique dans une application d'authentification.
3. Element le redirige vers Keycloak, où il saisit son mot de passe puis le code à six chiffres.
4. Synapse vérifie l'appartenance au groupe « agents » et ouvre une session pour cet appareil.
5. L'appareil génère ses clés et n'envoie au serveur que leur partie publique.

5.2 Envoi d'un message ou d'un fichier

1. L'application de l'expéditeur crée une clé de groupe pour la conversation (protocole Megolm).
2. Elle transmet cette clé à chaque appareil des membres, chiffrée séparément pour chacun (protocole Olm).
3. Le message est chiffré avec la clé de groupe. Un fichier est chiffré avant l'envoi (AES-256) et sa clé est placée dans le message chiffré.
4. Synapse stocke et relaie un contenu qu'il ne peut pas lire.
5. Chaque destinataire déchiffre le message sur son propre appareil.

5.3 Révocation d'un agent

1. L'administrateur choisit l'agent dans la console, clique sur « Révoquer » et indique un motif.
2. Keycloak désactive le compte et ferme ses sessions : l'agent ne peut plus se reconnecter.
3. Synapse invalide ses jetons de connexion, supprime ses appareils et leurs clés, et le retire de tous ses groupes.
4. Les autres membres changent automatiquement de clé de groupe : l'agent révoqué ne peut déchiffrer aucun nouveau message.
5. La console vérifie que plus aucun appareil ni aucun groupe ne lui est rattaché, puis enregistre l'opération dans le journal d'audit.

Deux systèmes doivent être coupés, car les sessions de messagerie sont indépendantes de l'annuaire : désactiver l'agent dans Keycloak l'empêche de revenir, désactiver son compte

dans Synapse coupe immédiatement les appareils déjà connectés. L'identité est coupée en premier, pour que l'agent ne puisse pas se reconnecter pendant l'opération.

6. Sécurité

6.1 Réponse au socle obligatoire

Exigence	Mise en œuvre	Démonstration
Chiffrement de bout en bout	Matrix (Olm et Megolm) par la bibliothèque officielle ; tous les groupes chiffrés par défaut ; fichiers chiffrés avant l'envoi	Inspection de la base de données
Aucune cryptographie maison	Aucune fonction de chiffrement écrite par l'équipe ; la console n'appelle que des API officielles	Lecture du code
Hébergement souverain	Installation en une commande ; serveurs de clés tiers, statistiques et aperçus de liens désactivés	Démarrage à froid, trafic du navigateur
Identité vérifiée	Inscription libre désactivée ; groupe « agents » exigé ; code TOTP obligatoire ; rôles par groupes	Tentative d'un compte non enrôlé
Révocation immédiate	Console agissant sur Keycloak puis Synapse, avec vérification et journal d'audit	Révocation pendant une conversation de groupe
Minimisation des métadonnées	Voir 6.2	Note de sécurité

6.2 Ce que le serveur voit

Le serveur ne voit jamais le contenu des messages, des fichiers ou des messages vocaux, ni les clés qui permettraient de les déchiffrer. Comme tout serveur Matrix, il voit en revanche certaines métadonnées : qui est membre de quel groupe, qui envoie un message et à quel moment, la taille approximative des contenus, les adresses IP et types d'appareils, ainsi que les noms des groupes et les noms affichés des agents, qui ne sont pas chiffrés par le protocole.

Pour réduire ces informations, l'indicateur de présence est désactivé, les adresses IP ne sont conservées qu'un jour, les notifications ne contiennent aucun contenu et passent par un service hébergé par l'État, et l'annuaire n'est pas consultable librement. Une consigne simple complète ces mesures : ne jamais placer d'information sensible dans le nom ou le sujet d'un groupe.

6.3 Limites connues

- Un appareil révoqué alors qu'il est hors ligne conserve ce qu'il avait déjà déchiffré jusqu'à sa reconnexion ; il ne peut en revanche lire aucun nouveau message.

- Les captures d'écran ne peuvent pas être bloquées dans un navigateur, et une photo de l'écran reste toujours possible.
- Un serveur compromis pourrait tenter d'ajouter un faux appareil à un compte ; la vérification des appareils entre agents limite ce risque.
- Aucun chiffrement ne protège contre un logiciel espion installé sur l'appareil d'un agent.
- Le prototype repose sur un seul serveur ; la fédération entre ministères est la réponse prévue à l'échelle nationale.

7. Innovation

Notre innovation principale porte sur les **langues nationales** : permettre aux agents d'échanger des messages vocaux en mooré ou en dioula, chiffrés comme le reste, et proposer les écrans essentiels de l'application dans ces langues. Cette fonction rend la messagerie accessible aux agents moins à l'aise à l'écrit ou en français, notamment dans les services déconcentrés. Elle ne modifie pas la sécurité, puisque les messages vocaux d'Element sont déjà chiffrés, et la traduction pourra être proposée au projet open source d'origine.

Deux fonctions complémentaires sont prévues si le délai le permet. La première est la **classification des messages** (« Diffusion restreinte », « Confidentiel ») avec des règles associées : bandeau visible, transfert interdit, expiration automatique ; le niveau de classification est stocké dans la partie chiffrée du message. La seconde est un **accusé de lecture à valeur probante** pour les instructions de service, sous la forme d'une confirmation chiffrée et signée par l'appareil de l'agent.

Enfin, l'architecture prépare plusieurs évolutions : un annuaire officiel des agents par ministère et par fonction, un archivage légal compatible avec le chiffrement (un compte « Archiviste » institutionnel, visible de tous, membre des groupes officiels) et la fédération des serveurs ministériels.

8. Organisation du travail

L'architecture découpe naturellement le travail entre deux personnes. La première prend en charge la partie messagerie (Synapse, Element, chiffrement, métadonnées et innovation) ; la seconde prend en charge la partie identité (Keycloak, console d'administration, révocation et tests de sécurité). Chacune travaille dans son propre dossier du dépôt, ce qui évite les conflits, et peut faire fonctionner sa partie seule avant l'assemblage.

L'assemblage repose sur trois accords écrits : la configuration de la connexion des agents (C1), l'accès interne de la console à Synapse (C2), et les conventions communes, c'est-à-dire les adresses, les noms des services et le format des identifiants, par exemple `@prenom.nom:messagerie.gov.bf`. Chaque accord est associé à un test qui confirme que les deux parties fonctionnent ensemble.

9. Licences et état d'avancement

Composant	Rôle	Licence
Synapse	Serveur Matrix	AGPL-3.0
Element Web	Application des agents	AGPL-3.0 ou GPL-3.0
vodozemac	Chiffrement Olm et Megolm	Apache-2.0
Keycloak	Gestion des identités	Apache-2.0
oauth2-proxy	Protection de la console	MIT
Caddy	Point d'entrée HTTPS	Apache-2.0
PostgreSQL	Bases de données	Licence PostgreSQL
FastAPI, HTTPX	Console d'administration	MIT, BSD-3-Clause
Docker Compose	Déploiement	Apache-2.0

Notre propre dépôt est publié sous licence AGPL-3.0, cohérente avec celles d'Element et de Synapse : toute amélioration apportée par un service de l'État reste ainsi ouverte.

Plusieurs éléments sont déjà vérifiés. L'assemblage des deux parties est valide, en configuration de démonstration comme de production. Synapse démarre avec notre configuration, ne propose que la connexion par le compte agent de l'État et refuse les mots de passe directs. La révocation a été testée de bout en bout sur un vrai serveur Synapse : en une demi-seconde environ, l'appareil de l'agent est refusé et l'agent quitte le groupe. Les groupes sont chiffrés par défaut et les inscriptions libres sont refusées, ce que confirment des tests automatisés. Il reste à valider la connexion complète par Keycloak avec code TOTP, à finaliser l'innovation et à répéter les épreuves de démonstration.

10. Conclusion

Ce projet propose une messagerie que l'État peut installer, comprendre, auditer et faire évoluer lui-même. Il s'appuie sur des logiciels open source reconnus plutôt que sur des développements risqués, réserve le code propre à l'équipe à ce qui manquait réellement pour l'administration, et décrit honnêtement ses limites. Il ne dépend d'aucun fournisseur étranger.